

Mahmud Hasan Sizan

Offensive Security Researcher · Bug Bounty Hunter
(twistedmock)

twistedmock@wearehackerone.com ·

twistedmock.com

hackerone.com/twistedmock ·

bugcrowd.com/twistedmock

github.com/Twistedmock · linkedin.com/in/twistedmock

Remote worldwide or relocating · GMT+6

SUMMARY

Top-1,000 all-time researcher on HackerOne with six years hunting web-application vulnerabilities. **185 valid reports (105 resolved) across 75 programs, 131 paid bounties, 57 rated critical or high, and HackerOne Clear** (background-checked). 82% of my reputation sits in 32 private, invitation-only programs — including one where I rank **#1 of every hunter on it**. Publicly credited by **Apple** (three times), **Google**, **Microsoft**, **Goldman Sachs**, **SpaceX**, **GitHub** and **Adobe**.

3,824 REPUTATION	#747 GLOBAL RANK	105 RESOLVED	75 PROGRAMS	131 PAID BOUNTIES	80th SIGNAL PCT.	84th IMPACT PCT.	57 CRITICAL / HIGH
---------------------	---------------------	-----------------	----------------	-------------------------	---------------------	---------------------	--------------------------

PLATFORMS

- HackerOne — twistedmock** (since May 2020). 3,824 reputation, global rank #747; 185 valid reports (105 resolved, 27 critical, 30 high); 131 bounties from 36 programs; signal 5.55 (80th percentile), impact 84th. HackerOne Clear. 18 badges across six OWASP categories; Milestone Level III; nine-month valid-report streak (Jan–Sep 2026). 32 private programs hold 3,135 reputation — one at rank #1 with 48 valid reports.
- Bugcrowd — twistedmock**. 64 valid findings; public hall of fame at SpaceX, Atlassian, Twilio, Bitdefender, Coca-Cola, United Airlines, Lenovo, Ibotta, Monash University and the U.S. Department of Veterans Affairs; three further programs private.

PUBLIC ACKNOWLEDGEMENTS

- Apple** — named in Apple's security acknowledgements (web server security) in February 2026, August 2025 and July 2025. support.apple.com/en-us/102774
- Goldman Sachs** — two bounties awarded, 3 May and 24 April 2026 (one a collaboration).
- GitHub** — report resolved 28 September 2021; GitHub Security Researcher.
- Hall of fame** — Apple, Google, Microsoft, Goldman Sachs, Samsung, Accenture, Achmea, the Dutch government, ShopClues, UNESCO (reflected XSS, 19 June 2025) and Deutsche Telekom (SSRF).
- Adobe** — five valid reports; four resolved inside six weeks, February–March 2023.
- 34 public HackerOne programs** — incl. PayPal, Palantir, Databricks, Spotify, Roblox, UPS, Xiaomi, AT&T, Kubernetes, Epic Games, Polygon, Hilton, Hyatt, Veeam and the U.S. GSA.

FOCUS AREAS

- Web application security** — authentication and session flaws, broken access control (IDOR, privilege escalation), injection, XXE, XSS, security misconfiguration — badge-confirmed on HackerOne. 185 valid reports by class: information disclosure 45, access control 37, authentication 31, XSS 22, open redirect 14, SSRF 6.
- Reconnaissance & attack-surface mapping** at estate scale — internet-wide asset discovery, subdomain and port intelligence without touching the target.
- AI-augmented pentesting** — personal harnesses built around Claude and Codex that run reconnaissance, triage, proof-of-concept drafting and reporting, with every exploitation step steered by me.
- Reporting** — clear reproduction, impact framing and remediation advice; 131 reports paid by mature programs.

TOOLING (OPEN SOURCE, RUST)

- qshodan** — extracts hosts from Shodan and defeats its 1,000-result ceiling by recursive query subdivision; validates, strips reserved ranges, deduplicates. github.com/Twistedmock/qshodan
- qport** — port discovery from Shodan InternetDB at ~500 req/s; no packets reach the asset owner. github.com/Twistedmock/qport
- Attack Surface Monitoring** (SaaS, in development) — Crunchbase, Shodan, Censys, Whoxy and crt.sh folded into one continuous picture.

Claude	Codex	Rust	Python	Bash	Burp Suite
Shodan	Censys	crt.sh	Whoxy	Linux	

LANGUAGES

English (fluent, IELTS Academic 8.0, 2024) · Bengali (native) · Hindi and Urdu (conversational — speaking and listening)

ROLES SOUGHT

Penetration tester · red team operator · application security engineer · vulnerability researcher · attack-surface / recon specialist. Full-time or contract; remote worldwide, or relocating.